

BloodDonationSystem - Unauthenticated

Generated with  ZAP on Tue 4 Aug 2026, at 22:44:43

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Contents

- [About This Report](#)
 - [Report Parameters](#)
- [Summaries](#)
 - [Alert Counts by Risk and Confidence](#)
 - [Alert Counts by Site and Risk](#)
 - [Alert Counts by Alert Type](#)
 - [Insights](#)
- [Alerts](#)
 - [Risk=High, Confidence=Low \(1\)](#)
 - [Risk=Medium, Confidence=High \(2\)](#)
 - [Risk=Medium, Confidence=Medium \(2\)](#)
 - [Risk=Medium, Confidence=Low \(1\)](#)

- [Risk=Low, Confidence=High \(1\).](#)
- [Risk=Low, Confidence=Medium \(4\).](#)
- [Risk=Informational, Confidence=High \(1\).](#)
- [Risk=Informational, Confidence=Medium \(2\).](#)
- [Appendix](#)
 - [Alert Types](#)

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- <http://192.168.100.50:5000>

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: [High](#), [Medium](#), [Low](#), [Informational](#)

Excluded: None

Confidence levels

Included: [User Confirmed](#), [High](#), [Medium](#), [Low](#)

Excluded: User Confirmed, High, Medium, Low, False Positive

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
Risk		User Confirmed	High	Medium	Low	Total
	High	0 (0.0%)	0 (0.0%)	0 (0.0%)	1 (7.1%)	1 (7.1%)
	Medium	0 (0.0%)	2 (14.3%)	2 (14.3%)	1 (7.1%)	5 (35.7%)
	Low	0 (0.0%)	1 (7.1%)	4 (28.6%)	0 (0.0%)	5 (35.7%)
	Informational	0 (0.0%)	1 (7.1%)	2 (14.3%)	0 (0.0%)	3 (21.4%)
	1	0 (0.0%)	1 (7.1%)	2 (14.3%)	0 (0.0%)	3 (21.4%)
Total		0 (0.0%)	4 (28.6%)	8 (57.1%)	2 (14.3%)	14 (100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

	Risk				Informational
	High (= High)	Medium (>= Medium)	Low (>= Low)	Low (>= Low)	
Site					
http://192.168.100.50:5000	1 (1)	5 (6)	5 (11)	5 (11)	3 (14)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
SQL Injection	High	2 (14.3%)
Absence of Anti-CSRF Tokens	Medium	3 (21.4%)
Buffer Overflow	Medium	7 (50.0%)
Content Security Policy (CSP) Header Not Set	Medium	3 (21.4%)
Total		14

Alert type	Risk	Count
Missing Anti-clickjacking Header	Medium	3 (21.4%)
Sub Resource Integrity Attribute Missing	Medium	2 (14.3%)
Cookie No HttpOnly Flag	Low	1 (7.1%)
Cookie without SameSite Attribute	Low	1 (7.1%)
Cross-Domain JavaScript Source File Inclusion	Low	3 (21.4%)
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	2 (14.3%)
X-Content-Type-Options Header Missing	Low	2 (14.3%)
Authentication Request Identified	Informational	1 (7.1%)
Session Management Response Identified	Informational	1 (7.1%)
User Agent Fuzzer	Informational	3 (21.4%)
Total		14

Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap.log file for details	1
Low	Exceeded High	http:// 192.16 8.100. 50:500 0	Percentage of responses with status code 5xx	58 %
Info	Informational		Percentage of network failures	1 %
Info	Informational	http:// 192.16 8.100. 50	Percentage of endpoints with content type text/plain	100 %
Info	Informational	http:// 192.16 8.100. 50	Percentage of endpoints with method GET	100 %
Info	Informational	http:// 192.16 8.100. 50	Count of total endpoints	1
Info	Informational	http:// 192.16 8.100. 50:500 0	Percentage of responses with status code 2xx	19 %
Info	Informational	http:// 192.16	Percentage of responses with	5 %

Level	Reason	Site	Description	Statistic
		8.100.50:5000	status code 3xx	
Info	Exceeded Low	http://192.168.100.50:5000	Percentage of responses with status code 4xx	16 %
Info	Informational	http://192.168.100.50:5000	Percentage of endpoints with content type text/css	9 %
Info	Informational	http://192.168.100.50:5000	Percentage of endpoints with content type text/html	90 %
Info	Informational	http://192.168.100.50:5000	Percentage of endpoints with method GET	81 %
Info	Informational	http://192.168.100.50:5000	Percentage of endpoints with method POST	18 %
Info	Informational	http://192.168.100.50:5000	Count of total endpoints	11

Level	Reason	Site	Description	Statistic
Info	Informational	https://cdn.jsdelivr.net	Percentage of responses with status code 2xx	100 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of endpoints with content type application/javascript	50 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of endpoints with content type text/css	50 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of endpoints with method GET	100 %
Info	Informational	https://cdn.jsdelivr.net	Count of total endpoints	2
Info	Informational	https://cdn.jsdelivr.net	Percentage of slow responses	37 %

Alerts

Risk=High, Confidence=Low (1)

<http://192.168.100.50:5000> (1)

SQL Injection (1)

▼ POST http://192.168.100.50:5000/staff/login

Alert tags

- POLICY_SEQUENCE =
- [OWASP 2021 A03](#)
- [PCI DSS](#)
- [CWE-89](#)
- POLICY_QA_CICD =
- POLICY_DEV_CICD =
- [OWASP 2025 A05](#)
- [WSTG-v42-INPV-05](#)
- POLICY_API =
- POLICY_DEV_FULL =
- POLICY_QA_STD =
- POLICY_QA_FULL =
- POLICY_PENTEST =
- [HIPAA](#)
- [OWASP 2017 A01](#)
- [API 2023 API10](#)
- POLICY_DEV_STD =

Alert description

SQL injection may be possible.

Request

▼ Request line and header section (369 bytes)

```
POST
http://192.168.100.50:5000/staff/login HTTP/1.1
host: 192.168.100.50:5000
user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36
pragma: no-cache
cache-control: no-cache
content-type: application/x-www-form-urlencoded
referer:
http://192.168.100.50:5000/staff/log
```

in
content-length: 25

▼ Request body (25 bytes)

username=%27&password=ZAP

Response

▼ Status line and header section (208 bytes)

HTTP/1.1 500 INTERNAL SERVER ERROR
Server: Werkzeug/3.0.3 Python/3.12.3
Date: Tue, 04 Aug 2026 14:39:44 GMT
Content-Type: text/html;
charset=utf-8
Content-Length: 1670
Vary: Cookie
Connection: close

▼ Response body (1670 bytes)

```
<!doctype html>
<html lang="en">
<head>
  <meta charset="utf-8">
  <meta name="viewport"
content="width=device-width,
initial-scale=1">
  <title>Blood Donation
System</title>
  <link
href="https://cdn.jsdelivrivr.net/npm/b
ootstrap@5.3.3/dist/css/bootstrap.mi
n.css" rel="stylesheet">
  <link rel="stylesheet"
href="/static/css/style.css">
</head>
<body>
<nav class="navbar navbar-expand-lg
navbar-dark bg-danger shadow-sm">
  <div class="container">
```

```

    <a class="navbar-brand fw-bold"
href="/"> Blood Donation System</a>
    <button class="navbar-toggler"
type="button" data-bs-
toggle="collapse" data-bs-
target="#nav"><span class="navbar-
toggler-icon"></span></button>
    <div class="collapse navbar-
collapse" id="nav">
        <ul class="navbar-nav ms-
auto">
            <li class="nav-item"><a
class="nav-link"
href="/donor/register">Donor
Registration</a></li>

            <li class="nav-item"><a
class="nav-link"
href="/staff/login">Staff Login</a>
</li>

        </ul>
    </div>
</div>
</nav>
<main>
    <div class="container py-4">

    <div class="alert alert-danger">
<h4>Application Error</h4><p>syntax
error at or near &#34;ZAP&#34;
LINE 1: ...FROM medical_staff WHERE
username = &#39;&#39;&#39; AND
password = &#39;ZAP&#39;

            ^
    </p></div>
    <div class="card"><div class="card-
body"><h6>Debug Query</h6>
    <pre>SELECT id, username,

```

```
full_name, role FROM medical_staff
WHERE username = &#39;&#39;&#39;
AND password = &#39;ZAP&#39;</pre>
</div></div>
```

```
</div>
</main>
<script
src="https://cdn.jsdelivr.net/npm/bootstrap@5.3.3/dist/js/bootstrap.bundle.min.js"></script>
</body>
</html>
```

Parameter

username

Attack

'

Evidence

HTTP/1.1 500 INTERNAL SERVER ERROR

Solution

Do not trust client side input, even if there is client side validation in place.

In general, type check all data on the server side.

If the application uses JDBC, use PreparedStatement or CallableStatement, with parameters passed by '?'

If the application uses ASP, use ADO Command Objects with strong type checking and parameterized queries.

If database Stored Procedures can be used, use them.

Do **not** concatenate strings into queries in the stored procedure, or use 'exec', 'exec immediate', or equivalent functionality!

Do not create dynamic SQL queries using simple string concatenation.

Escape all data received from the client.

Apply an 'allow list' of allowed characters, or a 'deny list' of disallowed characters in user input.

Apply the principle of least privilege by using the least privileged database user possible.

In particular, avoid using the 'sa' or 'db-owner' database users. This does not eliminate SQL injection, but minimizes its impact.

Grant the minimum database access that is necessary for the application.

Risk=Medium, Confidence=High (2)

<http://192.168.100.50:5000> (2)

Content Security Policy (CSP) Header Not Set (1)

▼ GET <http://192.168.100.50:5000/>

Alert tags

- [OWASP 2021 A05](#)
- POLICY_QA_STD =
- POLICY_PENTEST =
- [SYSTEMIC](#)
- [CWE-693](#)
- [OWASP 2017 A06](#)
- [OWASP 2025 A02](#)

Alert description

Content Security Policy (CSP) is an added layer of security that helps to

detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

Request

▼ Request line and header section (333 bytes)

```
GET http://192.168.100.50:5000/
HTTP/1.1
host: 192.168.100.50:5000
User-Agent: Mozilla/5.0 (X11; Linux
x86_64; rv:128.0) Gecko/20100101
Firefox/128.0
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
Upgrade-Insecure-Requests: 1
Priority: u=0, i
```

▼ Request body (0 bytes)

Response

▼ Status line and header section (189 bytes)

```
HTTP/1.1 200 OK
Server: Werkzeug/3.0.3 Python/3.12.3
Date: Tue, 04 Aug 2026 14:37:11 GMT
Content-Type: text/html; charset=utf-
```

8
Content-Length: 2563
Vary: Cookie
Connection: close

► Response body (2563 bytes)

Solution

Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

Sub Resource Integrity Attribute Missing (1)

▼ GET http://192.168.100.50:5000/

Alert tags

- [CWE-345](#)
- [OWASP 2021 A05](#)
- POLICY_QA_STD =
- POLICY_PENTEST =
- [SYSTEMIC](#)
- [OWASP 2017 A06](#)
- [OWASP 2025 A02](#)
- POLICY_DEV_STD =

Alert description

The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.

Request

▼ Request line and header section (333 bytes)

```
GET http://192.168.100.50:5000/  
HTTP/1.1  
host: 192.168.100.50:5000  
User-Agent: Mozilla/5.0 (X11; Linux  
x86_64; rv:128.0) Gecko/20100101
```

Firefox/128.0

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

Accept-Language: en-US,en;q=0.5

Connection: keep-alive

Upgrade-Insecure-Requests: 1

Priority: u=0, i

▼ Request body (0 bytes)

Response

▼ Status line and header section (189 bytes)

HTTP/1.1 200 OK

Server: Werkzeug/3.0.3 Python/3.12.3

Date: Tue, 04 Aug 2026 14:37:11 GMT

Content-Type: text/html;
charset=utf-8

Content-Length: 2563

Vary: Cookie

Connection: close

► Response body (2563 bytes)

Evidence

```
<link
href="https://cdn.jsdelivr.net/npm/bootstrap@5.3.3/dist/css/bootstrap.min.css" rel="stylesheet">
```

Solution

Provide a valid integrity attribute to the tag.

Risk=Medium, Confidence=Medium (2)

<http://192.168.100.50:5000> (2)

Buffer Overflow (1)

▼ POST http://192.168.100.50:5000/donor/register

Alert tags

- [OWASP 2025 A05](#)
- [OWASP 2021 A03](#)
- [PCI DSS](#)
- POLICY_API =
- POLICY_PENTEST =
- [OWASP 2017 A01](#)
- [API 2023 API10](#)
- [OWASP 2025 A10](#)
- [CWE-120](#)

Alert description

Buffer overflow errors are characterized by the overwriting of memory spaces of the background web process, which should have never been modified intentionally or unintentionally. Overwriting values of the IP (Instruction Pointer), BP (Base Pointer) and other registers causes exceptions, segmentation faults, and other process errors to occur. Usually these errors end execution of the application in an unexpected way.

Other info

Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error.

Request

▼ Request line and header section (377 bytes)

```
POST
http://192.168.100.50:5000/donor/register HTTP/1.1
host: 192.168.100.50:5000
user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36
pragma: no-cache
```

```

cache-control: no-cache
content-type: application/x-www-form-urlencoded
referer:
http://192.168.100.50:5000/donor/register
content-length: 2234

```

► Request body (2234 bytes)

Response

▼ Status line and header section (195 bytes)

```

HTTP/1.1 500 INTERNAL SERVER ERROR
Server: Werkzeug/3.0.3 Python/3.12.3
Date: Tue, 04 Aug 2026 14:41:56 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 16601
Connection: close

```

► Response body (16601 bytes)

Parameter

full_name

Attack

```

JYjiIDfpfGXXKlmMdFDQxgUwbBCDcOxWGDOAi
xfbmVvtlEfQiwRMssqqVqeQBoxZteutIHIBZf
umqZAIHUDwRqUbiQrAhNddoSfMTbkBLkjEBoA
PoOIMQUHfDqZNXmgECPnkACjxZBckRqVFsqrE
rvChZsMrbyVExprJfCXCIcHbNUqdqtZPiGnrC
drSfiraJoqtenXHxBVCpDdTMHiSuawOolIhVd
XiIpjmhWKadQUwsGgfwKwPbNbmOjlrUlRusNY
VGZWtiHhqVOOVwroMTwOGLoioqkDSSpnFvUw
FjDMpbiOYLduguPEaEgkvpfGeEdtbAJpGdIKm
vKgYvKgXFkkPIegZtyFRVedddZuFwIZUZfERc
kpHVRnTpYgXJYtQSvEsKiSqEmThFrJGLsyIEq
pShIumqSVDYHWKVqDDwJbSdUnSrPGYAeIGPGw
OriLotDgowWaNOfIPbNfStWrISdmtoptruxeQ
qXTtMtSegrljaxCQUVOeoenErQFVIsLYMkrmi

```

jxAdcfeCNZKjVakVFRuAbiNFafJkHJZiInmoI
WHefbIWDsmtCRVqNOQcDnnKjTGfOFpDsLeRom
bnydyRKYtHIjowhEkHbNxpdrWGUGsUMlJvkeM
ejgZMjEFeONweQiEaAhgkTfChYLHmYSvweuAS
HSxkueKPlcpxCfHlEYFjufdYRKiWiILXkNuIDF
hecAcBXFoKaGIJOpLXCaxxMQORFREhioiqHpy
FdKKMZyOTuCuLyNAxOUHnuxNVPmdcWISVxmyu
jvVdXlPIutaxYeqTIIFavKTIJXtFvZEKquyiL
JKmFPPFBctiIlqGrtdGbSvxQPvRvCDoQnPaOJ
ikfJoyeNDIqToRZpIhjSdfDxgVRrylwqWLLty
JGNZdshjfdJiUygpBCrugmseSHdGLsbqKAYiR
QxvuQJTrBvKvsMeZYpUfkJuQpurpmgXvPAYiT
nyhbIGCFGKYtCYArFTMGEDVEcxtgsCgmASQwO
MiRVWWLEbMQvwsMAEZKpCPdfHJbwTSZCnLDJx
pPehwZGDQQeltKjlfNJVhXnMVFjPqgPBXSnHL
wQJoiYDTfBcDvGQdPWlZUwyHmESSjSwChWjYu
WcaTvsFKrBSbKPXrjqxCZyCqMejnFpNUXJJhP
oIgoQGEKYSJJNTtpUNAkYXlIbvbIbiSoVIRis
bMQdSflLQSjdRbgaNWMPMAfIJkWTpdEvElLPC
hPbdOqbXLnRrVAasymBTPGehGpVKmiiIHfoky
NGCJBRFtjAeEuqAKLZiUyCbIscVeizelNXSrA
ldoygTRlARGfahZYgXfvfbdaPhqDfrssPnkjL
SCuSrJfuZWApLYuBcDHXlIEbXGqrkAQPNbViv
NKwPicWUaUkqqjlckeguMiJBpaXULjYOXIdCA
cQdnPgNgIIMlqcHBiGVEIkQCKHeovqsChoSBg
jCRhdSdtnkyXhXwyYsFdaoGFDqwOAmCunWZhF
OntPWxlgivsMVXTOixdeiehWXZxeZqRhHtDSg
kJhNxrNLDiabMKIWBQwhMFYDnEMmhlvmGGEDt
mruwIBDYKCGrnYgZlupBRBKHValvfXAUCDIDY
ZBsxeUHLvXmQJtlCAOvISBReapVlLtacHahGG
PspWuFAMGODPWKNdvyFeOclnOIwKRlyJmWUQX
RGFneXHyLvwDabpIrgoirGdOBPHrGkVuXyIHJ
HgNNnDukkVipSjYloDnVFkQCoKlmKvKUBUMIo
yFuiYckIOBvDoCPEncPsLMcCgbqKNOWTZMVVU
yuZQovmcgpsjoDtDtncDHgiIkrXGUJLCQgYVt
rIyAKuLFlsdYbpLXfuthKvduvKYerntIFFXHO
iSBSyhnJYSHORDEhtXAHZTVVjPBplBmhbyMYd
rkgqgAoLKvwqnNjhDxxUYgJaQIwOMVnWOIbAu
gnMtQTxnqbAbgqGuQPkohwVeKpmvAiwnFSHqg
qcoQPJlKqsRQKyJrFYXFwhOBgxDaAbbMZpaxC
XFDouBnqaJVxghVQXQhvtLwWoZWTNBjIQWVbG
YBlrxkwxFkkuRHpxqMXQaFXyVsviqWxHJDAPt
ernHQRyAGYbXbRFEDVPCytAJozji

Evidence

Connection: close

Solution

Rewrite the background program using proper return length checking. This will require a recompile of the background executable.

Missing Anti-clickjacking Header (1)

▼ GET http://192.168.100.50:5000/

Alert tags

- [OWASP 2021 A05](#)
- POLICY_QA_STD =
- POLICY_PENTEST =
- [CWE-1021](#)
- [SYSTEMIC](#)
- [WSTG-v42-CLNT-09](#)
- [OWASP 2017 A06](#)
- [OWASP 2025 A02](#)

Alert description

The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

Request

▼ Request line and header section (333 bytes)

```
GET http://192.168.100.50:5000/
HTTP/1.1
host: 192.168.100.50:5000
User-Agent: Mozilla/5.0 (X11; Linux
x86_64; rv:128.0) Gecko/20100101
Firefox/128.0
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
Upgrade-Insecure-Requests: 1
```

Priority: u=0, i

▼ Request body (0 bytes)

Response

▼ Status line and header section (189 bytes)

HTTP/1.1 200 OK

Server: Werkzeug/3.0.3 Python/3.12.3

Date: Tue, 04 Aug 2026 14:37:11 GMT

Content-Type: text/html;
charset=utf-8

Content-Length: 2563

Vary: Cookie

Connection: close

► Response body (2563 bytes)

Parameter

x-frame-options

Solution

Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app.

If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.

Risk=Medium, Confidence=Low (1)

<http://192.168.100.50:5000> (1)

Absence of Anti-CSRF Tokens (1)

▼ GET <http://192.168.100.50:5000/staff/login>

Alert tags

- [OWASP 2021 A01](#)
- POLICY_QA_STD =
- POLICY_PENTEST =
- [SYSTEMIC](#)
- [WSTG-v42-SESS-05](#)
- [OWASP 2025 A01](#)
- [OWASP 2017 A05](#)
- [CWE-352](#)
- POLICY_DEV_STD =

Alert description

No Anti-CSRF tokens were found in a HTML submission form.

A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session riding, confused deputy, and sea surf.

CSRF attacks are effective in a number of situations, including:

- * The victim has an active session on the target site.

- * The victim is authenticated via HTTP auth on the target site.

- * The victim is on the same local network as the target site.

CSRF has primarily been used to perform an action against a target site using the victim's privileges, but recent techniques have been discovered to disclose information by gaining access to the response. The risk of information disclosure is dramatically increased when the target site is vulnerable to XSS, because XSS can be used as a platform for CSRF, allowing the attack to operate within the bounds of the same-origin policy.

Other info

No known Anti-CSRF token [anticsrf, CSRFToken, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken] was found in the following HTML form: [Form 1: "password" "username"].

Request

▼ Request line and header section (287 bytes)

```
GET
http://192.168.100.50:5000/staff/login HTTP/1.1
host: 192.168.100.50:5000
user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
```

(KHTML, like Gecko) Chrome/141.0.0.0
Safari/537.36
pragma: no-cache
cache-control: no-cache
referer: http://192.168.100.50:5000

▼ Request body (0 bytes)

Response

▼ Status line and header section (189 bytes)

HTTP/1.1 200 OK
Server: Werkzeug/3.0.3 Python/3.12.3
Date: Tue, 04 Aug 2026 14:39:32 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 1931
Vary: Cookie
Connection: close

▼ Response body (1931 bytes)

```
<!doctype html>
<html lang="en">
<head>
  <meta charset="utf-8">
  <meta name="viewport"
content="width=device-width, initial-
scale=1">
  <title>Blood Donation
System</title>
  <link
href="https://cdn.jsdelivr.net/npm/bo
otstrap@5.3.3/dist/css/bootstrap.min.
css" rel="stylesheet">
  <link rel="stylesheet"
href="/static/css/style.css">
</head>
<body>
<nav class="navbar navbar-expand-lg
```



```
navbar-dark bg-danger shadow-sm">
  <div class="container">
    <a class="navbar-brand fw-bold"
href="/"> Blood Donation System</a>
    <button class="navbar-toggler"
type="button" data-bs-
toggle="collapse" data-bs-
target="#nav"><span class="navbar-
toggler-icon"></span></button>
    <div class="collapse navbar-
collapse" id="nav">
      <ul class="navbar-nav ms-auto">
        <li class="nav-item"><a
class="nav-link"
href="/donor/register">Donor
Registration</a></li>

        <li class="nav-item"><a
class="nav-link"
href="/staff/login">Staff Login</a>
</li>

      </ul>
    </div>
  </div>
</nav>
<main>
  <div class="container py-4">

  <div class="row justify-content-
center">
    <div class="col-md-5">
      <div class="card shadow-sm
border-0">
        <div class="card-header bg-
white"><h3 class="mb-0">Medical
Staff Login</h3></div>
        <div class="card-body">
          <form method="post">
            <div class="mb-3"><label
```

```

class="form-label">Username</label>
<input name="username" class="form-
control" required></div>
    <div class="mb-3"><label
class="form-label">Password</label>
<input type="password"
name="password" class="form-control"
required></div>
    <button class="btn btn-
danger w-100">Login</button>
  </form>
  <div class="small text-muted
mt-3">Seed account: nurse01 /
Password123</div>
</div>
</div>
</div>
</div>
</div>
</div>
</main>
<script
src="https://cdn.jsdelivr.net/npm/boo
tstrap@5.3.3/dist/js/bootstrap.bundle
.min.js"></script>
</body>
</html>

```

Evidence

```
<form method="post">
```

Solution

Phase: Architecture and Design

Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid.

For example, use anti-CSRF packages such as the OWASP CSRFGuard.

Phase: Implementation

Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script.

Phase: Architecture and Design

Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330).

Note that this can be bypassed using XSS.

Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation.

Note that this can be bypassed using XSS.

Use the ESAPI Session Management control.

This control includes a component for CSRF.

Do not use the GET method for any request that triggers a state change.

Phase: Implementation

Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons.

Risk=Low, Confidence=High (1)**<http://192.168.100.50:5000> (1)****Server Leaks Version Information via "Server" HTTP Response Header Field (1)**▼ GET <http://192.168.100.50:5000/static/css/style.css>**Alert tags**

- [OWASP 2021 A05](#)
- POLICY_QA_STD =
- POLICY_PENTEST =
- [SYSTEMIC](#)
- [OWASP 2017 A06](#)
- [WSTG-v42-INFO-02](#)
- [CWE-497](#)
- [OWASP 2025 A02](#)

Alert description

The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.

Request

▼ Request line and header section (313 bytes)

```
GET
http://192.168.100.50:5000/static/css/style.css HTTP/1.1
host: 192.168.100.50:5000
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/css,*/*;q=0.1
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
Referer: http://192.168.100.50:5000/
```

Priority: u=2

▼ Request body (0 bytes)

Response

▼ Status line and header section (367 bytes)

```
HTTP/1.1 200 OK
Server: Werkzeug/3.0.3 Python/3.12.3
Date: Tue, 04 Aug 2026 14:37:11 GMT
Content-Disposition: inline;
filename=style.css
Content-Type: text/css; charset=utf-8
Content-Length: 763
Last-Modified: Thu, 30 Apr 2026
13:03:00 GMT
Cache-Control: no-cache
ETag: "1777554180.0-763-2936738339"
Date: Tue, 04 Aug 2026 14:37:11 GMT
Connection: close
```

▼ Response body (763 bytes)

```
body { background: #f7f7fb; }
.hero { background: linear-
gradient(135deg, #b00020, #e53935);
}
.blood-drop { font-size: 8rem;
filter: drop-shadow(0 12px 18px
rgba(0,0,0,.25)); }
.stat-card { background: #fff;
border-radius: 1rem; padding:
1.5rem; box-shadow: 0 .5rem 1.5rem
rgba(0,0,0,.07); border-left: 6px
solid #dc3545; }
.stat-card span { color: #6c757d;
display: block; }
.stat-card strong { font-size:
2.5rem; color: #b00020; }
```

```
.record-box { border-left: 4px
solid #dc3545; background: #fff5f5;
padding: .75rem; margin-bottom:
.75rem; border-radius: .5rem; }
.update-output { min-height: 240px;
white-space: pre-wrap; background:
#111827; color: #e5e7eb; padding:
1rem; border-radius: .75rem; }
.card { border-radius: 1rem; }
.btn { border-radius: .6rem; }
```

Evidence

Werkzeug/3.0.3 Python/3.12.3

Solution

Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.

Risk=Low, Confidence=Medium (4)<http://192.168.100.50:5000> (4)**Cookie No HttpOnly Flag (1)**▼ POST <http://192.168.100.50:5000/donor/register>**Alert tags**

- [CWE-1004](#)
- [OWASP 2021 A05](#)
- POLICY_QA_STD =
- [WSTG-v42-SESS-02](#)
- POLICY_PENTEST =
- [SYSTEMIC](#)
- [OWASP 2017 A06](#)
- [OWASP 2025 A02](#)
- POLICY_DEV_STD =

Alert description

A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this

page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible.

Request

▼ Request line and header section (376 bytes)

```
POST
http://192.168.100.50:5000/donor/register HTTP/1.1
host: 192.168.100.50:5000
user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0
Safari/537.36
pragma: no-cache
cache-control: no-cache
content-type: application/x-www-form-urlencoded
referer:
http://192.168.100.50:5000/donor/register
content-length: 137
```

▼ Request body (137 bytes)

```
full_name=ZAP&email=zaproxy%40example.com&phone=9999999999&ic_number=ZAP&gender=Female&date_of_birth=2026-08-04&address=688+Zaproxy+Ridge
```

Response

▼ Status line and header section (391 bytes)

```
HTTP/1.1 302 FOUND
Server: Werkzeug/3.0.3 Python/3.12.3
Date: Tue, 04 Aug 2026 14:39:32 GMT
Content-Type: text/html;
charset=utf-8
Content-Length: 217
```

Location: /staff/donor/11

Vary: Cookie

Set-Cookie:

session=eyJfZmxhc2hlcyI6W3siIHQiOl^{si}
c3VjY2VzcyIsIlJlZ2lzdHJhdGlvbiBzdWNj
ZXNzZnVsLiBZb3VyIERvbm9yIElEIGlzIDEx
LiJdfV19.anH5pA.i2E9Sf-

10IoRt7a3Zh7TL9N-DFg; Path=/
Connection: close

▼ Response body (217 bytes)

```
<!doctype html>  
<html lang=en>  
<title>Redirecting...</title>  
<h1>Redirecting...</h1>  
<p>You should be redirected  
automatically to the target URL: <a  
href="/staff/donor/11">/staff/donor/  
11</a>. If not, click the link.
```

Parameter

session

Evidence

Set-Cookie: session

Solution

Ensure that the HttpOnly flag is set for all cookies.

Cookie without SameSite Attribute (1)

▼ POST http://192.168.100.50:5000/donor/register

Alert tags

- [OWASP 2021 A01](#)
- POLICY_QA_STD =
- [WSTG-v42-SESS-02](#)
- POLICY_PENTEST =
- [SYSTEMIC](#)
- [CWE-1275](#)
- [OWASP 2025 A01](#)
- [OWASP 2017 A05](#)
- POLICY_DEV_STD =

**Alert
description**

A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.

Request**▼ Request line and header section (376 bytes)**

```
POST
http://192.168.100.50:5000/donor/register HTTP/1.1
host: 192.168.100.50:5000
user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0
Safari/537.36
pragma: no-cache
cache-control: no-cache
content-type: application/x-www-form-urlencoded
referer:
http://192.168.100.50:5000/donor/register
content-length: 137
```

▼ Request body (137 bytes)

```
full_name=ZAP&email=zaproxy%40example.com&phone=9999999999&ic_number=ZAP
&gender=Female&date_of_birth=2026-08-04&address=688+Zaproxy+Ridge
```

Response**▼ Status line and header section (391 bytes)**

```
HTTP/1.1 302 FOUND
Server: Werkzeug/3.0.3 Python/3.12.3
```

Date: Tue, 04 Aug 2026 14:39:32 GMT
Content-Type: text/html;
charset=utf-8
Content-Length: 217
Location: /staff/donor/11
Vary: Cookie
Set-Cookie:
session=eyJfZmxhc2hlcyI6W3siIHQiOlsi
c3VjY2VzcyIsIlJlZ2lzdHJhdGlvbiBzdWNj
ZXNzZnVsLiBZb3VyIERvbm9yIElEIGlzIDEx
LiJdfV19.anH5pA.i2E9Sf-
l0IoRt7a3Zh7TL9N-DFg; Path=/
Connection: close

▼ Response body (217 bytes)

```
<!doctype html>
<html lang=en>
<title>Redirecting...</title>
<h1>Redirecting...</h1>
<p>You should be redirected
automatically to the target URL: <a
href="/staff/donor/11">/staff/donor/
11</a>. If not, click the link.
```

Parameter	session
Evidence	Set-Cookie: session
Solution	Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.

Cross-Domain JavaScript Source File Inclusion (1)

▼ GET http://192.168.100.50:5000/

Alert tags

- [OWASP 2025 A08](#)
- POLICY_QA_STD =
- POLICY_PENTEST =
- [SYSTEMIC](#)

- [OWASP 2021 A08](#)
- [CWE-829](#)
- POLICY_DEV_STD =

Alert description

The page includes one or more script files from a third-party domain.

Request

▼ Request line and header section (333 bytes)

```
GET http://192.168.100.50:5000/
HTTP/1.1
host: 192.168.100.50:5000
User-Agent: Mozilla/5.0 (X11; Linux
x86_64; rv:128.0) Gecko/20100101
Firefox/128.0
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
Upgrade-Insecure-Requests: 1
Priority: u=0, i
```

▼ Request body (0 bytes)

Response

▼ Status line and header section (189 bytes)

```
HTTP/1.1 200 OK
Server: Werkzeug/3.0.3 Python/3.12.3
Date: Tue, 04 Aug 2026 14:37:11 GMT
Content-Type: text/html;
charset=utf-8
Content-Length: 2563
Vary: Cookie
Connection: close
```

► Response body (2563 bytes)

Parameter	<code>https://cdn.jsdelivr.net/npm/bootstrap@5.3.3/dist/js/bootstrap.bundle.min.js</code>
Evidence	<code><script src="https://cdn.jsdelivr.net/npm/bootstrap@5.3.3/dist/js/bootstrap.bundle.min.js"></script></code>
Solution	Ensure JavaScript source files are loaded from only trusted sources, and the sources can't be controlled by end users of the application.

X-Content-Type-Options Header Missing (1)

▼ GET `http://192.168.100.50:5000/static/css/style.css`

- | | |
|-------------------|--|
| Alert tags | <ul style="list-style-type: none"> ▪ OWASP 2021 A05 ▪ POLICY_QA_STD = ▪ POLICY_PENTEST = ▪ SYSTEMIC ▪ CWE-693 ▪ OWASP 2017 A06 ▪ OWASP 2025 A02 |
|-------------------|--|

Alert description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
--------------------------	---

Other info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by
-------------------	--

injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.

At "High" threshold this scan rule will not alert on client or server error responses.

Request

▼ Request line and header section (313 bytes)

```
GET
http://192.168.100.50:5000/static/css
/style.css HTTP/1.1
host: 192.168.100.50:5000
User-Agent: Mozilla/5.0 (X11; Linux
x86_64; rv:128.0) Gecko/20100101
Firefox/128.0
Accept: text/css,*/*;q=0.1
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
Referer: http://192.168.100.50:5000/
Priority: u=2
```

▼ Request body (0 bytes)

Response

▼ Status line and header section (367 bytes)

```
HTTP/1.1 200 OK
Server: Werkzeug/3.0.3 Python/3.12.3
Date: Tue, 04 Aug 2026 14:37:11 GMT
Content-Disposition: inline;
filename=style.css
Content-Type: text/css; charset=utf-8
Content-Length: 763
Last-Modified: Thu, 30 Apr 2026
13:03:00 GMT
Cache-Control: no-cache
ETag: "1777554180.0-763-2936738339"
Date: Tue, 04 Aug 2026 14:37:11 GMT
```

Connection: close

▼ Response body (763 bytes)

```
body { background: #f7f7fb; }
.hero { background: linear-
gradient(135deg, #b00020, #e53935); }
.blood-drop { font-size: 8rem;
filter: drop-shadow(0 12px 18px
rgba(0,0,0,.25)); }
.stat-card { background: #fff;
border-radius: 1rem; padding:
1.5rem; box-shadow: 0 .5rem 1.5rem
rgba(0,0,0,.07); border-left: 6px
solid #dc3545; }
.stat-card span { color: #6c757d;
display: block; }
.stat-card strong { font-size:
2.5rem; color: #b00020; }
.record-box { border-left: 4px solid
#dc3545; background: #fff5f5;
padding: .75rem; margin-bottom:
.75rem; border-radius: .5rem; }
.update-output { min-height: 240px;
white-space: pre-wrap; background:
#111827; color: #e5e7eb; padding:
1rem; border-radius: .75rem; }
.card { border-radius: 1rem; }
.btn { border-radius: .6rem; }
```

Parameter

x-content-type-options

Solution

Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages.

If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be

directed by the web application/web server to not perform MIME-sniffing.

Risk=Informational, Confidence=High (1)

<http://192.168.100.50:5000> (1)

Authentication Request Identified (1)

▼ POST <http://192.168.100.50:5000/staff/login>

Alert tags

Alert description

The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.

Other info

userParam=username

userValue=ZAP

passwordParam=password

referer=<http://192.168.100.50:5000/staff/login>

Request

▼ Request line and header section (369 bytes)

POST

<http://192.168.100.50:5000/staff/login>
in HTTP/1.1

host: 192.168.100.50:5000

user-agent: Mozilla/5.0 (Windows NT

```
10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/141.0.0.0
Safari/537.36
pragma: no-cache
cache-control: no-cache
content-type: application/x-www-
form-urlencoded
referer:
http://192.168.100.50:5000/staff/log
in
content-length: 25
```

▼ Request body (25 bytes)

```
username=ZAP&password=ZAP
```

Response

▼ Status line and header section (269 bytes)

```
HTTP/1.1 200 OK
Server: Werkzeug/3.0.3 Python/3.12.3
Date: Tue, 04 Aug 2026 14:39:32 GMT
Content-Type: text/html;
charset=utf-8
Content-Length: 2185
Vary: Cookie
Set-Cookie: session=; Expires=Thu,
01 Jan 1970 00:00:00 GMT; Max-
Age=0; Path=/
Connection: close
```

► Response body (2185 bytes)

Parameter

username

Evidence

password

Solution

This is an informational alert rather than a vulnerability and so there is

nothing to fix.

Risk=Informational, Confidence=Medium (2)

<http://192.168.100.50:5000> (2)

Session Management Response Identified (1)

▼ POST <http://192.168.100.50:5000/donor/register>

Alert tags

Alert description

The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.

Other info

cookie:session

Request

▼ Request line and header section (376 bytes)

POST

<http://192.168.100.50:5000/donor/register> HTTP/1.1

host: 192.168.100.50:5000

user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)

AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0

Safari/537.36

pragma: no-cache

cache-control: no-cache

```
content-type: application/x-www-  
form-urlencoded  
referer:  
http://192.168.100.50:5000/donor/reg  
ister  
content-length: 137
```

▼ Request body (137 bytes)

```
full_name=ZAP&email=zaproxy%40exampl  
e.com&phone=9999999999&ic_number=ZAP  
&gender=Female&date_of_birth=2026-  
08-04&address=688+Zaproxy+Ridge
```

Response

▼ Status line and header section (391 bytes)

```
HTTP/1.1 302 FOUND  
Server: Werkzeug/3.0.3 Python/3.12.3  
Date: Tue, 04 Aug 2026 14:39:32 GMT  
Content-Type: text/html;  
charset=utf-8  
Content-Length: 217  
Location: /staff/donor/11  
Vary: Cookie  
Set-Cookie:  
session=eyJfZmxhc2hlcyI6W3siIHQiOl  
si  
c3VjY2VzcyIsIlJlZ2lzdHJhdGlvbiBzdW  
Nj  
ZXNzZnVsLiBZb3VyIERvbm9yIElEI  
GzIDEx  
LiJdfV19.anH5pA.i2E9Sf-  
l0IoRt7a3Zh7TL9N-DFg; Path=/  
Connection: close
```

▼ Response body (217 bytes)

```
<!doctype html>  
<html lang=en>  
<title>Redirecting...</title>  
<h1>Redirecting...</h1>  
<p>You should be redirected  
automatically to the target URL: <a
```

href="/staff/donor/11">/staff/donor/11. If not, click the link.

Parameter session

Evidence session

Solution This is an informational alert rather than a vulnerability and so there is nothing to fix.

User Agent Fuzzer (1)

▼ POST http://192.168.100.50:5000/donor/register

Alert tags

- CUSTOM_PAYLOADS =
- POLICY_PENTEST =
- [SYSTEMIC](#)

Alert description Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.

Request ▼ Request line and header section (315 bytes)

```
POST
http://192.168.100.50:5000/donor/register HTTP/1.1
host: 192.168.100.50:5000
user-agent: Mozilla/4.0
(compatible; MSIE 8.0; Windows NT 6.1)
pragma: no-cache
cache-control: no-cache
content-type: application/x-www-form-urlencoded
referer:
http://192.168.100.50:5000/donor/reg
```

05/08/2026, 16:13		BloodDonationSystem - Unauthenticated	
		<code>ister</code> <code>content-length: 137</code>	
		▼ Request body (137 bytes)	
		<code>full_name=ZAP&email=zaproxy%40example.com&phone=9999999999&ic_number=ZAP&gender=Female&date_of_birth=2026-08-04&address=688+Zaproxy+Ridge</code>	
Response		▼ Status line and header section (195 bytes)	
		<code>HTTP/1.1 500 INTERNAL SERVER ERROR</code> <code>Server: Werkzeug/3.0.3 Python/3.12.3</code> <code>Date: Tue, 04 Aug 2026 14:42:00 GMT</code> <code>Content-Type: text/html;</code> <code>charset=utf-8</code> <code>Content-Length: 16923</code> <code>Connection: close</code>	
		► Response body (16923 bytes)	
Parameter		Header User-Agent	
Attack		<code>Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)</code>	

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

SQL Injection

Source	raised by an active scanner (SQL Injection)
CWE ID	89
WASC ID	19
Reference	■ https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

Absence of Anti-CSRF Tokens

Source	raised by a passive scanner (Absence of Anti-CSRF Tokens)
CWE ID	352
WASC ID	9
Reference	■ https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html ■ https://cwe.mitre.org/data/definitions/352.html

Buffer Overflow

Source	raised by an active scanner (Buffer Overflow)
CWE ID	120
WASC ID	7
Reference	■ https://owasp.org/www-community/attacks/Buffer_overflow_attack

Content Security Policy (CSP) Header Not Set

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP ▪ https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html ▪ https://www.w3.org/TR/CSP/ ▪ https://w3c.github.io/webappsec-csp/ ▪ https://web.dev/articles/csp ▪ https://caniuse.com/#feat=contentsecuritypolicy ▪ https://content-security-policy.com/

Missing Anti-clickjacking Header

Source	raised by a passive scanner (Anti-clickjacking Header)
CWE ID	1021
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

Sub Resource Integrity Attribute Missing

Source	raised by a passive scanner (Sub Resource Integrity Attribute Missing)
CWE ID	345
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity

Cookie No HttpOnly Flag

Source	raised by a passive scanner (Cookie No HttpOnly Flag)
CWE ID	1004
WASC ID	13
Reference	▪ https://owasp.org/www-community/HttpOnly

Cookie without SameSite Attribute

Source	raised by a passive scanner (Cookie without SameSite Attribute)
CWE ID	1275
WASC ID	13
Reference	▪ https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site

Cross-Domain JavaScript Source File Inclusion

Source	raised by a passive scanner (Cross-Domain JavaScript Source File Inclusion)
CWE ID	829
WASC ID	15

Server Leaks Version Information via "Server" HTTP Response Header Field

Source	raised by a passive scanner (HTTP Server Response Header)
CWE ID	497
WASC ID	13
Reference	▪ https://httpd.apache.org/docs/current/mod/core.html#servertokens ▪ https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) ▪ https://www.troyhunt.com/shhh-dont-let-your-response-headers/

X-Content-Type-Options Header Missing

Source	raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID	693
WASC ID	15
Reference	▪ https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)

- <https://owasp.org/www-community/Security-Headers>

Authentication Request Identified

Source raised by a passive scanner ([Authentication Request Identified](#))

Reference

- <https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/>

Session Management Response Identified

Source raised by a passive scanner ([Session Management Response Identified](#))

Reference

- <https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/>

User Agent Fuzzer

Source raised by an active scanner ([User Agent Fuzzer](#))

Reference

- <https://owasp.org/wstg>